

CNO V: Seguridad Informática

Mtro. Servando López Contreras

PARCIALES



Fundamentos del hacking ético.

- a. Introducción al hacking ético y a las pruebas de penetración.
- b. Planeación y definición del alcance de una evaluación de pruebas de penetración.
- c. Recolección de información y escaneo de vulnerabilidades.



Técnicas de explotación de vulnerabilidades y seguridad en entornos tecnológicos.

- a. Ataques de ingeniería social.
- b. Explotación de redes cableadas e inalámbricas.
- c. Explotación de vulnerabilidades en aplicaciones.
- d. Seguridad en entornos de computación en la nube, dispositivos móviles e internet de las cosas (IoT).



Post-explotación y reportes de seguridad.

- a. Ejecución de técnicas de post-explotación.
- b. Elaboración de reportes y comunicación de resultados.
- c. Análisis de herramientas y código.

FORMA DE EVALUACIÓN

PROYECTO P1

De la teoría a la práctica: walkthrough en acción (guía y video).

PROYECTO P2

El eslabón más débil: diseño ético de una campaña de ingeniería social.

PROYECTO P3

Bajo la lupa: evaluación de ciberseguridad en un corporativo.

	PARCIAL I	PARCIAL II	PARCIAL III	EVALUACIÓN ORDINARIA	EVALUACIÓN EXTRAORDINARIA	EVALUACIÓN DE REGULARIZACIÓN
Actividades	60	60	60	Portafolio digital (100%)	-	-
Proyecto	30	30	30		-	-
Examen	10	10	10		100	100
TOTAL (%)	100	100	100		100	100

El **portafolio digital** constituye el compendio integral de las *actividades, prácticas y proyectos desarrollados por el estudiante a lo largo de la asignatura*.

Su finalidad es documentar de manera estructurada y sistemática el proceso de aprendizaje, así como las competencias técnicas adquiridas en materia de seguridad informática.

El portafolio integra ejercicios prácticos de pruebas de penetración, análisis de vulnerabilidades, uso y documentación de herramientas especializadas, evidencias audiovisuales (videos demostrativos) y resultados obtenidos durante el curso. Asimismo, permite reflejar la capacidad del estudiante para organizar, comunicar y presentar información técnica de forma profesional.

El portafolio deberá desarrollarse y publicarse en una plataforma digital, preferentemente mediante **repositorios en GitHub** o a través de un **desarrollo web nativo**, garantizando accesibilidad, orden, claridad y buenas prácticas de documentación.

Estructura mínima general:

- **Inicio.**
- **Notas.**
- **Herramientas.**
- **Proyectos.**
- **Certificaciones.**

Fechas de examen:

Parcial I: martes 17 de febrero de 2026.

Parcial II: martes 24 de marzo de 2026.

Parcial III: martes 19 de mayo de 2026.

Final: martes 26 de mayo de 2026 (por confirmar).

ET: martes 02 de junio de 2026 (por confirmar).

ER: martes 09 de junio de 2026 (por confirmar).

Sistema de calificaciones:

Aprobatorio: ≥ 7.0

Acreditar una asistencia no menor a las dos terceras partes del período que comprende el examen.

Redondeo de decimales: 7.3 = 7.0

7.4 = 7.5

1.4 = 1

1.5 = 1

7.5 = 7.5

1.8 = 1

6.9 = 6

7.8 = 7.5

7.9 = 8.0

Semestre 2025-2026

www.upslp.edu.mx

Calendario Escolar

UNIVERSIDAD
POLITECNICA
DE SAN LUIS POTOSÍ

D	L	M	M	J	V	S
					1	2
3	4	5	6	7	8	9
10	11	12	13	14	15	16
17	18	19	20	21	22	23
24	25	26	27	28	29	30
31						

D	L	M	M	J	V	S
		1	2	3	4	5
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30				

D	L	M	M	J	V	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30	31	

D	L	M	M	J	V	S
						1
2	3	4	5	6	7	8
9	10	11	12	13	14	15
16	17	18	19	20	21	22
23	24	25	26	27	28	29
30						

- ▶ Inicio de semestre
- ▶ Fin de semestre
- ☑ Evaluaciones parciales
- ♦ Evaluaciones finales
- ▶ Evaluaciones extraordinarias
- ➔ Evaluaciones de regularización
- ☀ Suspensión de labores
- ★ Límite para baja temporal y registro de anteproyecto

D	L	M	M	J	V	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30	31			

D	L	M	M	J	V	S
				1	2	3
4	5	6	7	8	9	10
11	12	13	14	15	16	17
18	19	20	21	22	23	24
25	26	27	28	29	30	31

D	L	M	M	J	V	S
1	2	3	4	5	6	7
8	9	10	11	12	13	14
15	16	17	18	19	20	21
22	23	24	25	26	27	28

D	L	M	M	J	V	S
1	2	3	4	5	6	7
8	9	10	11	12	13	14
15	16	17	18	19	20	21
22	23	24	25	26	27	28
29	30	31				

- ☀ Vacaciones escolares
- ☀ Receso Académico
- ☀ Curso de verano
- ✔ Límite para acreditar la residencia profesional
- ✔ Límite para baja de materias
- ☀ Selección de horarios
- ☀ Examen EGEL
- ☀ Ceremonia de titulación
- ☀ 25 Aniversario
- ☀ Día de la calidad

D	L	M	M	J	V	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30		

D	L	M	M	J	V	S
				1	2	
3	4	5	6	7	8	9
10	11	12	13	14	15	16
17	18	19	20	21	22	23
24	25	26	27	28	29	30
31						

D	L	M	M	J	V	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30				

D	L	M	M	J	V	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30	31	

- Periodo de entrega de fichas del Ciclo 2026: del 3 de noviembre de 2025 al 28 de mayo de 2026
- Aplicación de EXANI II: 13 de junio
- Resultados de EXANI II: 14 julio
- Inscripción de cursos de verano
- Graduación: 13 de febrero

PERIODOS DE PAGO
DE REINSCRIPCIÓN:

PRIMAVERA 2026:
del 10 al 18 de diciembre
OTOÑO 2026:
del 10 al 18 de junio

TIPOS DE PRUEBAS DE PENETRACIÓN

PRUEBAS DE INFRAESTRUCTURA DE RED

Las **pruebas de infraestructura de red** consisten en evaluar la **seguridad real de los componentes que soportan la comunicación de una red**, identificando debilidades técnicas que podrían ser explotadas por un atacante.

01 Analizar la postura de seguridad de la red.

02 Comprender cómo se llevan a cabo los ataques.

03 Aprender cómo prevenirlos o mitigarlos.

¿Qué componentes se evalúan?



Conmutadores (Switches)

- VLANs mal configuradas
- Trunking inseguro
- Ataques como VLAN hopping



Enrutadores (Routers)

- Credenciales débiles
- Servicios administrativos expuestos
- Rutas mal configuradas



Cortafuegos (Firewalls)

- Reglas permisivas
- Puertos innecesarios abiertos
- Errores en políticas de filtrado



Servicios AAA (Authentication, Authorization, Accounting)

- Fallas en autenticación
- Mala gestión de privilegios
- Registros insuficientes



IPS / IDS

- Detección ineficiente
- Firmas desactualizadas
- Alertas ignoradas o mal configuradas

RECOMENDACIÓN

X.800

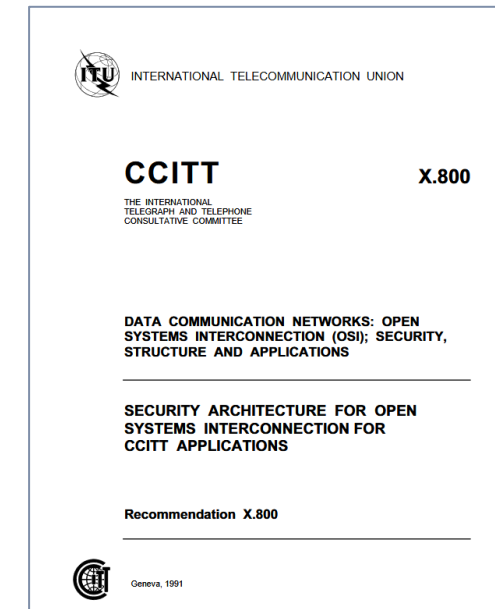
ITU-T X.800: “Security Architecture for Open Systems Interconnection (OSI) for CCITT Applications”,
publicada originalmente en **1991**.

Su objetivo es proporcionar un marco conceptual unificado para entender, planificar e implementar la seguridad en redes de comunicación y sistemas interconectados.



Emitida por la Unión Internacional de Telecomunicaciones — UIT

<https://www.itu.int/es/Pages/default.aspx#/es>



<https://www.itu.int/rec/t-rec-x.800-199103-i/es>

ITU-T X.800

CONTEXTO HISTÓRICO

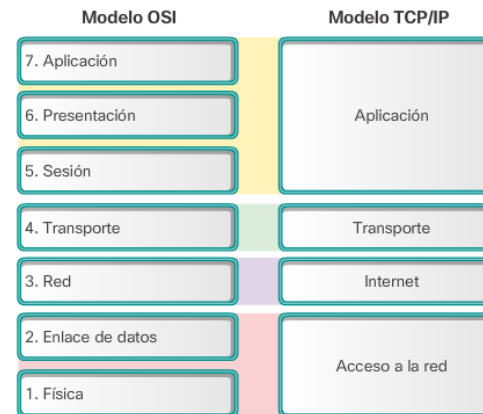
Cuando se desarrolló el modelo OSI (Open Systems Interconnection), en los años 80-90, **se buscaba estandarizar cómo se comunican los sistemas de diferentes fabricantes.**

Sin embargo, el modelo OSI no definía cómo asegurar esas comunicaciones.

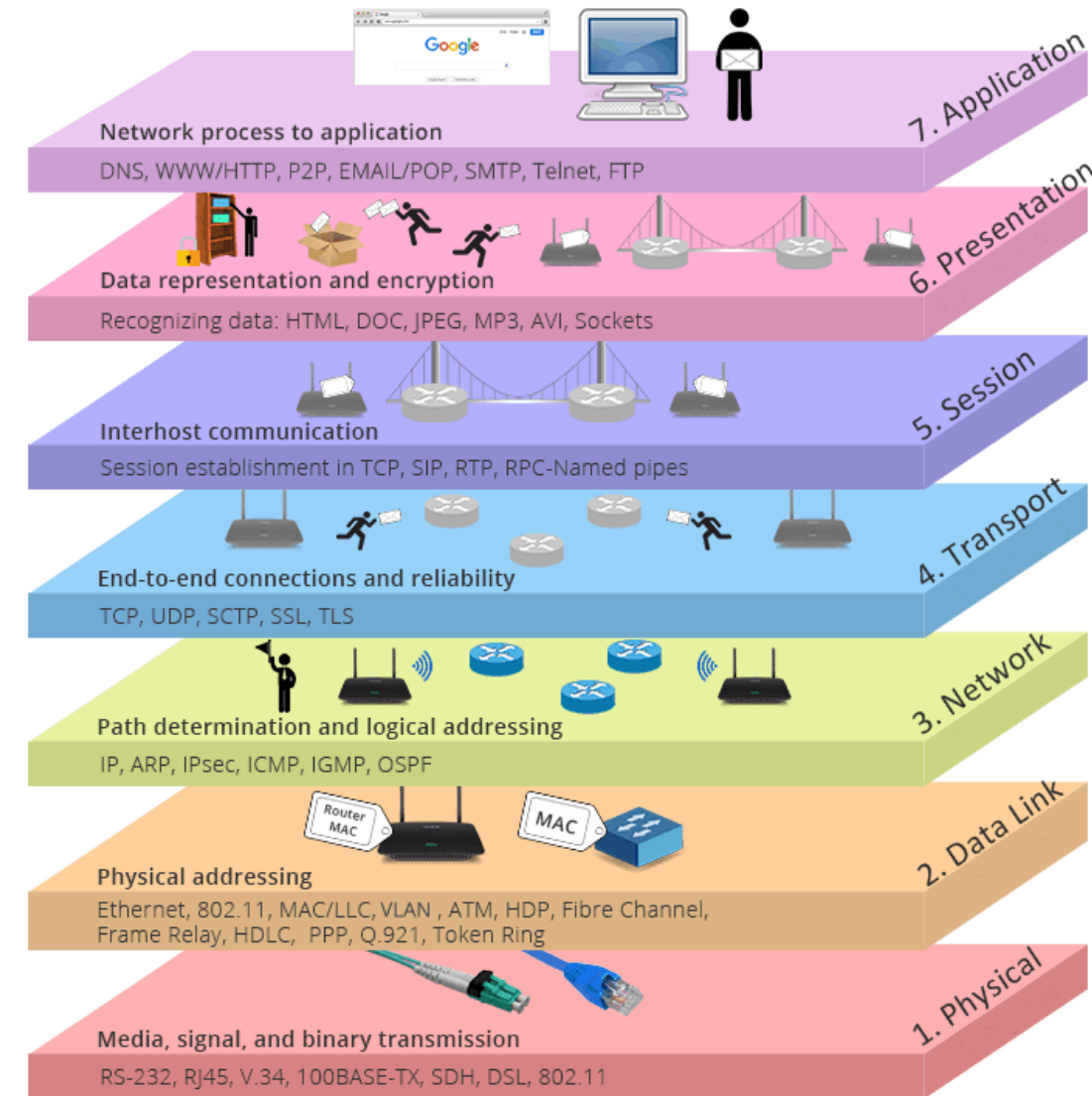
Por eso, la UIT publicó la X.800, que:

- complementa al modelo OSI con una capa transversal de seguridad,
- **define principios, servicios y mecanismos,**
- y sirve como base para otras normas posteriores, **como ISO/IEC 7498-2** y las familias ISO 27000.

Comparación entre el modelo OSI y el modelo TCP/IP



Las similitudes clave se encuentran en la capa de transporte y en la capa de red. Sin embargo, los dos modelos se diferencian en el modo en que se relacionan con las capas que están por encima y por debajo de cada capa.



ITU-T X.800

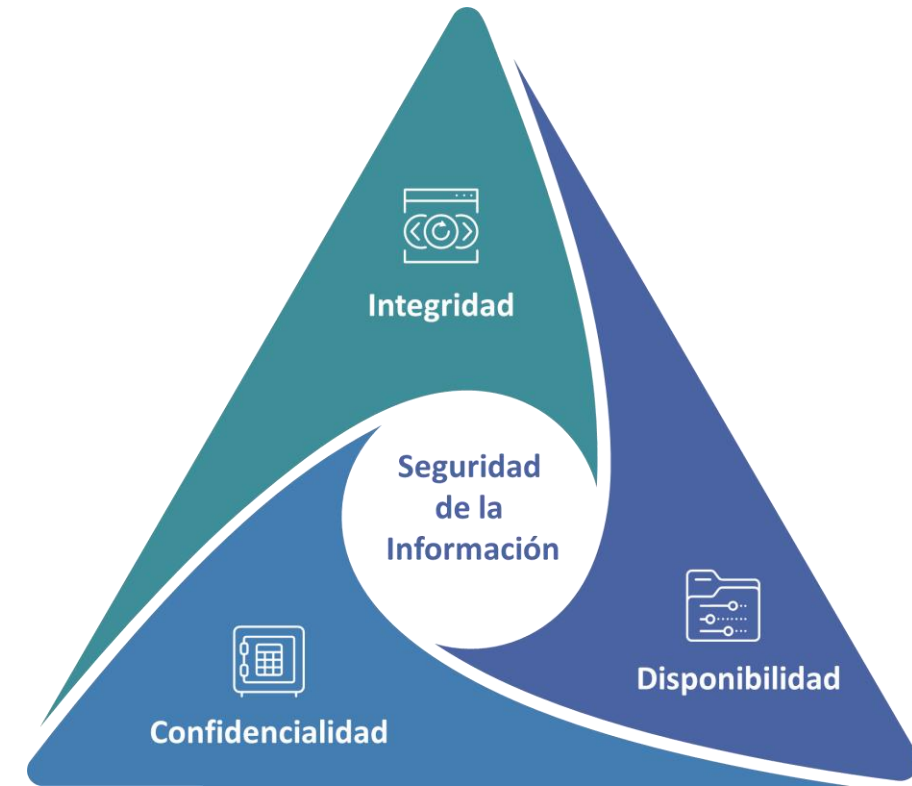
OBJETIVOS PRINCIPALES

- 01 Proteger los datos** frente a amenazas como pérdida, alteración o acceso no autorizado.
- 02 Asegurar la autenticidad** de las entidades que participan en la comunicación.
- 03 Garantizar la disponibilidad** de los servicios de red.
- 04 Ofrecer una estructura de referencia** para diseñar e implementar controles de seguridad coherentes en todas las capas del modelo OSI.

ITU-T X.800

OBJETIVOS PRINCIPALES

- 01 Proteger los datos** frente a amenazas como pérdida, alteración o acceso no autorizado.
- 02 Asegurar la autenticidad** de las entidades que participan en la comunicación.
- 03 Garantizar la disponibilidad** de los servicios de red.
- 04 Ofrecer una estructura de referencia** para diseñar e implementar controles de seguridad coherentes en todas las capas del modelo OSI.



ITU-T X.800

SERVICIOS DE SEGURIDAD

La X.800 **define seis servicios de seguridad fundamentales**, aplicables a cualquier sistema de comunicación:

N°	Servicio	Descripción	Ejemplo práctico
01	Autenticación	Verifica la identidad de las entidades que se comunican.	<i>Inicio de sesión con usuario/contraseña o certificados digitales.</i>
02	Control de acceso	Garantiza que solo usuarios autorizados puedan acceder a recursos.	<i>Políticas ACL, firewalls, roles RBAC.</i>
03	Confidencialidad de datos	Protege la información de accesos no autorizados durante la transmisión.	<i>Cifrado TLS, VPN, cifrado AES.</i>
04	Integridad de datos	Asegura que los datos no sean alterados durante la transmisión.	<i>Hash SHA-256, firmas digitales.</i>
05	No repudio	Evita que una entidad niegue haber participado en una transacción.	<i>Firmas digitales, certificados X.509.</i>
06	Disponibilidad	Garantiza que los sistemas y servicios estén operativos cuando se necesiten.	<i>Redundancia, mitigación DDoS, backups.</i>

ITU-T X.800

SERVICIOS DE SEGURIDAD

Analiza cuidadosamente cada escenario.

Identifica qué servicio de seguridad está involucrado según ITU-T X.800:

- A) Autenticación
- B) Control de Acceso
- C) Confidencialidad de Datos
- D) Integridad de Datos
- E) No Repudio
- F) Disponibilidad

1. Durante un ataque de phishing dirigido, un empleado recibe un correo falso que lo lleva a un portal aparentemente oficial. El sistema corporativo implementa un módulo que valida si el portal pertenece realmente a la entidad que afirma ser antes de permitir el inicio de sesión.
2. En una investigación policial digital, un expediente compartido entre unidades de análisis se envía cifrado. Solo los agentes con credenciales específicas pueden descifrar la información para evitar filtraciones internas o espionaje.
3. Una empresa detecta que varios archivos de facturación fueron alterados en tránsito por un atacante en un ataque "man-in-the-middle". Para evitar esto, ahora implementan firmas criptográficas que permitan detectar cualquier modificación.
4. En un proceso judicial, se presenta evidencia digital que incluye la firma digital del funcionario que la generó. Esta firma permite demostrar que dicho funcionario no puede negar que fue él quien emitió el documento originalmente.
5. Un atacante intenta acceder a la base de datos central de una dependencia gubernamental usando credenciales robadas. Sin embargo, los sistemas verifican políticas granulares que niegan el acceso a recursos sensibles basándose en roles, ubicación y nivel de riesgo.

ITU-T X.800

SERVICIOS DE SEGURIDAD

Analiza cuidadosamente cada escenario.

Identifica qué servicio de seguridad está involucrado según ITU-T X.800:

- A) Autenticación
- B) Control de Acceso
- C) Confidencialidad de Datos
- D) Integridad de Datos
- E) No Repudio
- F) Disponibilidad

6. El portal de emergencias 911 comienza a recibir un ataque DDoS que intenta saturar su infraestructura para impedir que la población pueda llamar. La red cuenta con mitigación automática, red distribuida y servidores redundantes para asegurar la continuidad del servicio.
7. Para acceder al sistema de videovigilancia municipal, los operadores deben autenticarse usando doble factor: token físico más biometría. El sistema valida la identidad antes de permitir cualquier acceso.
8. Un malware dentro de la red intenta ejecutar procesos que no corresponden al rol del equipo infectado. Las políticas de seguridad impiden que este equipo acceda a ciertos recursos críticos, frenando la propagación del ataque.
9. Un informe de inteligencia se transmite entre dos centros de análisis. El receptor calcula el hash del mensaje recibido y lo compara con el hash enviado originalmente para verificar que el contenido no fue alterado.
10. Una plataforma de compras gubernamentales exige a los proveedores que utilicen certificados digitales válidos para autenticar al servidor antes de enviar documentos de licitación y datos financieros sensibles.

ITU-T X.800

SERVICIOS DE SEGURIDAD

Analiza cuidadosamente cada escenario.

Identifica qué servicio de seguridad está involucrado según ITU-T X.800:

- A) Autenticación
- B) Control de Acceso
- C) Confidencialidad de Datos
- D) Integridad de Datos
- E) No Repudio
- F) Disponibilidad

1. Durante un ataque de phishing dirigido, un empleado recibe un correo falso que lo lleva a un portal aparentemente oficial. El sistema corporativo implementa un módulo que valida si el portal pertenece realmente a la entidad que afirma ser antes de permitir el inicio de sesión. **Autenticación.**
2. En una investigación policial digital, un expediente compartido entre unidades de análisis se envía cifrado. Solo los agentes con credenciales específicas pueden descifrar la información para evitar filtraciones internas o espionaje. **Confidencialidad de datos.**
3. Una empresa detecta que varios archivos de facturación fueron alterados en tránsito por un atacante en un ataque "man-in-the-middle". Para evitar esto, ahora implementan firmas criptográficas que permitan detectar cualquier modificación. **Integridad de datos.**
4. En un proceso judicial, se presenta evidencia digital que incluye la firma digital del funcionario que la generó. Esta firma permite demostrar que dicho funcionario no puede negar que fue él quien emitió el documento originalmente. **No repudio.**
5. Un atacante intenta acceder a la base de datos central de una dependencia gubernamental usando credenciales robadas. Sin embargo, los sistemas verifican políticas granulares que niegan el acceso a recursos sensibles basándose en roles, ubicación y nivel de riesgo. **Control de acceso.**

ITU-T X.800

SERVICIOS DE SEGURIDAD

Analiza cuidadosamente cada escenario.

Identifica qué servicio de seguridad está involucrado según ITU-T X.800:

- A) Autenticación
- B) Control de Acceso
- C) Confidencialidad de Datos
- D) Integridad de Datos
- E) No Repudio
- F) Disponibilidad

6. El portal de emergencias 911 comienza a recibir un ataque DDoS que intenta saturar su infraestructura para impedir que la población pueda llamar. La red cuenta con mitigación automática, red distribuida y servidores redundantes para asegurar la continuidad del servicio. **Disponibilidad.**
7. Para acceder al sistema de videovigilancia municipal, los operadores deben autenticarse usando doble factor: token físico más biometría. El sistema valida la identidad antes de permitir cualquier acceso. **Autenticación.**
8. Un malware dentro de la red intenta ejecutar procesos que no corresponden al rol del equipo infectado. Las políticas de seguridad impiden que este equipo acceda a ciertos recursos críticos, frenando la propagación del ataque. **Control de acceso.**
9. Un informe de inteligencia se transmite entre dos centros de análisis. El receptor calcula el hash del mensaje recibido y lo compara con el hash enviado originalmente para verificar que el contenido no fue alterado. **Integridad de datos.**
10. Una plataforma de compras gubernamentales exige a los proveedores que utilicen certificados digitales válidos para autenticar al servidor antes de enviar documentos de licitación y datos financieros sensibles. **Autenticación.**

ITU-T X.800

MECANISMOS DE SEGURIDAD

La recomendación también define **mecanismos** (*las herramientas técnicas*) que implementan los servicios anteriores.

Estos se agrupan en **específicos** y **comunes**.

Mecanismos **específicos**

Aplican directamente a un servicio:

1. Cifrado (para confidencialidad)
2. Firma digital (para autenticación y no repudio)
3. Integridad de datos (hash, MAC)
4. Control de acceso
5. Relleno de tráfico (traffic padding): disfraza patrones de comunicación.
6. Ruteo seguro
7. Notarización electrónica (certificación de un documento).

Mecanismos **comunes**

Apoyan varios servicios de forma transversal:

1. Gestión de claves criptográficas
2. Gestión de seguridad (políticas, auditorías, monitoreo)
3. Etiquetado de seguridad
4. Gestión de eventos y alarmas

ITU-T X.800

RELACIÓN CON EL MODELO OSI

Aunque la seguridad se considera transversal, la X.800 permite aplicar **medidas específicas** en **cada capa del modelo OSI**.

Capa OSI	Amenaza típica	Mecanismo sugerido
Aplicación	Suplantación de identidad	<i>Autenticación y no repudio</i>
Sesión	Secuestro de sesión	<i>Control de acceso y cifrado</i>
Red	Manipulación de paquetes	<i>Ruteo seguro, detección de intrusiones</i>
Enlace	Escucha o manipulación ARP	<i>Integridad de datos, detección de anomalías</i>
Física	Interferencia o sabotaje	<i>Blindaje, redundancia.</i>

RFC 4949

GLOSARIO OFICIAL

El **RFC 4949** es uno de los documentos más importantes en materia de **terminología y fundamentos conceptuales de seguridad informática**. Es emitido por la **IETF (Internet Engineering Task Force)** y sirve como **glosario oficial** de los términos utilizados en el ámbito de la seguridad en redes, criptografía y protocolos de Internet.

- **Título completo:** RFC 4949: Internet Security Glossary, Version 2
- **Autor:** Russell L. (Russ) Shirey, del U.S. Department of Defense (DoD)
- **Fecha de publicación:** Agosto de 2007
- **Emisor:** IETF (Internet Engineering Task Force) — organismo responsable de los estándares técnicos de Internet.

Network Working Group
Request for Comments: 4949
FYI: 36
Obsoletes: [2828](#)
Category: Informational

R. Shirey
August 2007

Internet Security Glossary, Version 2

Status of This Memo

This memo provides information for the Internet community. It does not specify an Internet standard of any kind. Distribution of this memo is unlimited.

Copyright Notice

Copyright (C) The IETF Trust (2007).

RFC Editor Note

This document is both a major revision and a major expansion of the Security Glossary in [RFC 2828](#). This revised Glossary is an extensive reference that should help the Internet community to improve the clarity of documentation and discussion in an important area of Internet technology. However, readers should be aware of the following:

(1) The recommendations and some particular interpretations in definitions are those of the author, not an official IETF position. The IETF has not taken a formal position either for or against recommendations made by this Glossary, and the use of [RFC 2119](#) language (e.g., SHOULD NOT) in the Glossary must be understood as unofficial. In other words, the usage rules, wording interpretations, and other recommendations that the Glossary offers are personal opinions of the Glossary's author. Readers must judge for themselves whether or not to follow his recommendations, based on their own knowledge combined with the reasoning presented in the Glossary.

(2) The glossary is rich in the history of early network security work, but it may be somewhat incomplete in describing recent security work, which has been developing rapidly.

<https://datatracker.ietf.org/doc/html/rfc4949>

RFC 4949

GLOSARIO OFICIAL

El RFC 4949 incluye **más de 800 definiciones** relacionadas con:

Categoría	Ejemplos de términos definidos
Criptografía	AES, hash, firma digital, clave pública/privada, HMAC, nonce.
Protocolos de seguridad	IPsec, SSL/TLS, SSH, Kerberos.
Servicios de seguridad	Autenticación, confidencialidad, integridad, no repudio, control de acceso.
Modelos y políticas	Política de seguridad, dominio de confianza, perímetro de seguridad.
Amenazas y ataques	Spoofing, replay, denial of service, insider threat.
Gestión de identidades	Certificados, autoridades de certificación (CA), revocación, CRL.

ACTIVIDAD 02 - Análisis de servicios de seguridad (X.800 y RFC 4949)

Objetivo general:

Analizar escenarios de incidentes de seguridad informática mediante la aplicación de los seis servicios de seguridad definidos en el ITU-T X.800 y el uso preciso de la terminología establecida en el RFC 4949, con el fin de fortalecer la capacidad del estudiante para identificar, explicar y documentar vulneraciones de seguridad en contextos reales.

Objetivos específicos:

- **Identificar** los servicios de seguridad del ITU-T X.800 comprometidos en distintos escenarios de incidente, reconociendo la interrelación entre autenticación, control de acceso, confidencialidad, integridad, no repudio y disponibilidad.
- **Aplicar correctamente** la terminología y definiciones del RFC 4949 para describir de manera técnica y estandarizada los tipos de amenazas, vulnerabilidades, ataques e impactos asociados a cada escenario analizado.
- **Relacionar y contrastar** el enfoque conceptual del ITU-T X.800 con el marco terminológico del RFC 4949, demostrando su complementariedad para la comunicación profesional, el análisis técnico y la documentación de incidentes de seguridad informática.

Duración aproximada:

01 hora y 10 minutos.

Para **cada escenario**, complete **toda la ficha de análisis**, utilizando terminología correcta y argumentación técnica.

Escenario 0.

Accesos legítimos fuera de horario con credenciales válidas. El atacante modifica reglas internas para mantener acceso persistente.

Elemento	Respuesta
Servicios X.800 comprometidos.	Autenticación, Control de acceso, Integridad.
Definición(es) aplicable(s) RFC 4949.	Authentication, Authorization, Credential compromise, Privilege escalation (definir cada uno).
Tipo de amenaza.	Externa (con uso de credenciales válidas).
Vector de ataque.	Compromiso de credenciales y modificación de reglas.
Impacto técnico / operativo.	Acceso persistente no autorizado, pérdida de control del sistema.
Medida de control recomendada.	MFA robusto, detección de anomalías, revisión de privilegios, hardening de reglas.

ACTIVIDAD 02 - Análisis de servicios de seguridad (X.800 y RFC 4949)

Escenario 01.

En múltiples incidentes atribuidos al grupo LockBit, organizaciones públicas y privadas han sufrido el cifrado masivo de servidores tras un acceso inicial no autorizado. Antes de ejecutar el ransomware, los atacantes exfiltraron información sensible y posteriormente amenazaron con su publicación, evidenciando un compromiso simultáneo de la confidencialidad, la integridad y la disponibilidad.

Desde el enfoque del RFC 4949, el incidente se clasifica como un *multi-stage attack* con *data breach* y *availability attack*, donde la indisponibilidad del sistema es solo una fase final del daño. La ausencia de respaldos inmutables y de detección temprana permitió que el impacto fuera total.

Escenario 02.

En diversos casos documentados, bases de datos completas quedaron accesibles públicamente debido a errores de configuración en servicios de almacenamiento en la nube. No existió una explotación técnica sofisticada, sino una falla en el **control de acceso**, lo que derivó directamente en la pérdida de **confidencialidad de los datos**. El RFC 4949 describe este tipo de incidentes como *misconfiguration* y *exposure*, subrayando que la amenaza no siempre implica malware o intrusión activa. El impacto suele ser legal y reputacional, aun cuando no se pueda demostrar acceso malicioso.

Escenario 03.

Un proveedor legítimo de software fue comprometido y distribuyó una actualización que incluía código malicioso, afectando a cientos de organizaciones que confiaban en él. Este escenario refleja una violación grave de la **integridad de los sistemas** y, en muchos casos, de la **confidencialidad**, al permitir accesos no autorizados posteriores. El RFC 4949 lo identifica como *supply chain attack*, destacando el abuso de relaciones de confianza. El daño es particularmente crítico porque rompe el supuesto de legitimidad del software firmado.

Escenario 04.

Mediante campañas de phishing, atacantes obtuvieron credenciales válidas y accedieron a sistemas corporativos durante meses sin levantar alertas. Aunque la autenticación funcionó técnicamente, el servicio de **autenticación** fue comprometido al basarse en credenciales robadas, afectando también el **control de acceso**. Según el RFC 4949, se trata de un *credential compromise* con *authentication failure* conceptual, no técnica. La falta de MFA y de monitoreo de comportamiento facilitó la persistencia del atacante.

ACTIVIDAD 02 - Análisis de servicios de seguridad (X.800 y RFC 4949)

Escenario 05.

En ataques de ransomware avanzados, los atacantes eliminaron o cifraron los respaldos antes de afectar los sistemas productivos. Este hecho compromete directamente la **disponibilidad** y la **integridad** de la información, al impedir la recuperación. El RFC 4949 clasifica este comportamiento como *data destruction* y *availability attack*, evidenciando intención deliberada de maximizar el daño. La inexistencia de respaldos offline o inmutables convierte el incidente en catastrófico.

Escenario 06.

Un empleado con acceso legítimo extrajo bases de datos completas y las vendió a terceros, sin explotar vulnerabilidades técnicas. El servicio afectado fue principalmente la **confidencialidad**, junto con fallas en el **control de acceso** por exceso de privilegios. El RFC 4949 define este escenario como *insider threat*, destacando que el riesgo interno puede ser tan grave como el externo. La carencia de monitoreo y de políticas de mínimo privilegio fue determinante.

Escenario 07.

Tras un ataque, los registros del sistema quedaron cifrados o alterados, impidiendo reconstruir la secuencia de eventos. Esto compromete la **integridad de los datos** y el **no repudio**, ya que no es posible demostrar qué ocurrió ni quién fue responsable. Desde el RFC 4949, se trata de una violación de *evidentiary integrity* y del *audit trail*. El impacto no solo es técnico, sino también probatorio y legal.

Escenario 08.

Una actualización mal ejecutada provocó la caída simultánea de múltiples servicios críticos a nivel global. Aunque no existió un atacante, el servicio de **disponibilidad** fue gravemente afectado. El RFC 4949 contempla estos eventos como *operational failure*, recordando que la seguridad también se ve afectada por errores internos. La falta de pruebas previas y planes de reversión amplificó el impacto.

ACTIVIDAD 02 - Análisis de servicios de seguridad (X.800 y RFC 4949)

Escenario 09.

Atacantes replicaron sitios y correos oficiales para engañar a ciudadanos y obtener información sensible. Este escenario afecta la **autenticación**, al suplantar identidades legítimas, y la **confidencialidad** de los datos recolectados. El RFC 4949 lo clasifica como *masquerade* y *phishing*, subrayando el componente de ingeniería social. La ausencia de mecanismos de autenticación del dominio y de concientización facilitó el éxito del ataque.

Escenario 10.

En algunos incidentes, tras exfiltrar información, los atacantes ejecutaron acciones destructivas para borrar sistemas completos y eliminar rastros. Se produce un compromiso total de la **confidencialidad**, la **integridad** y la **disponibilidad**, configurando uno de los peores escenarios posibles. El RFC 4949 describe este patrón como *destructive attack*, donde el objetivo no es solo el lucro, sino el daño irreversible. La detección tardía impidió cualquier contención efectiva.

ACTIVIDAD 02 - Análisis de servicios de seguridad (X.800 y RFC 4949)

Rúbrica de evaluación:

Criterio	Ponderación total	Excelente	Bueno	Regular	Insuficiente
01. Elaboración de introducción y contexto del X.800 y el RFC 4949.	20 pts.	18–20 pts. — Introducción clara, bien estructurada y contextualizada; explica el propósito de ambos marcos, su relación y relevancia en la seguridad informática actual.	14–17 pts. — Introducción correcta, explica los marcos pero con menor profundidad o articulación entre ambos.	10–13 pts. — Contexto general, descriptivo y poco integrado; comprensión parcial de los estándares.	0–9 pts. — Introducción ausente, confusa o incorrecta; no demuestra comprensión de los marcos.
02. Incluye referencias y conclusiones.	15 pts.	14–15 pts. — Reflexión crítica, contextualizada y con propuestas aplicables al entorno latinoamericano.	11–13 pts. — Conclusión clara, aunque limitada en profundidad o propuesta.	8–10 pts. — Superficial o repetitiva, sin aportes relevantes.	0–7 pts. — Ausente o sin coherencia con el análisis.
03. Calidad en la presentación del informe.	15 pts.	14–15 pts. — Informe ejecutivo de alta calidad, redacción técnica, clara y ordenada; formato profesional, sin errores ortográficos o de estilo.	11–13 pts. — Presentación adecuada con errores menores de redacción o formato.	8–10 pts. — Presentación descuidada o poco clara; errores frecuentes.	0–7 pts. — Desordenado, difícil de leer o sin estructura.
04. Identificación de servicios de seguridad del ITU-T X.800	20 pts.	18–20 pts. — Identifica correctamente uno o varios servicios por escenario, justificando su elección de manera precisa.	14–17 pts. — Identificación correcta en la mayoría de los casos, con justificación parcial.	10–13 pts. — Identificación incompleta o poco argumentada.	0–9 pts. — Identificación incorrecta o ausente.
05. Uso correcto de la terminología del RFC 4949	15 pts.	14–15 pts. — Emplea términos técnicos precisos y adecuados al contexto de cada escenario.	11–13 pts. — Uso correcto, aunque limitado o poco variado.	8–10 pts. — Uso básico o impreciso de la terminología.	0–7 pts. — Uso incorrecto o inexistente del vocabulario técnico.
06. Análisis del impacto y propuesta de medidas de control	15 pts.	14–15 pts. — Analiza impactos técnicos, operativos o legales y propone medidas coherentes y viables.	11–13 pts. — Análisis correcto, con medidas generales o poco desarrolladas.	8–10 pts. — Análisis superficial; medidas poco claras o genéricas.	0–7 pts. — No identifica impactos ni propone controles.
	100 pts.				

ATAQUES A LA SEGURIDAD

Ataques activos

Tiene como objetivo la **alteración de los recursos del sistema** pudiendo afectar a su funcionamiento.

Por el contrario, la finalidad de un ataque pasivo no es alterar la comunicación sino “escuchar” y analizar el tráfico de la red sin afectar a los recursos del mismo.



ATAQUES A LA SEGURIDAD

Ataques pasivos

Aquel en el cual un atacante **monitorea de forma no autorizada el tráfico de la red** para capturar contraseñas u otra información para su uso posterior.

Principalmente hay dos tipos de ataques pasivos:

1. la obtención de contenidos de
2. mensajes y el análisis de tráfico.



FIREWALL IPTABLES

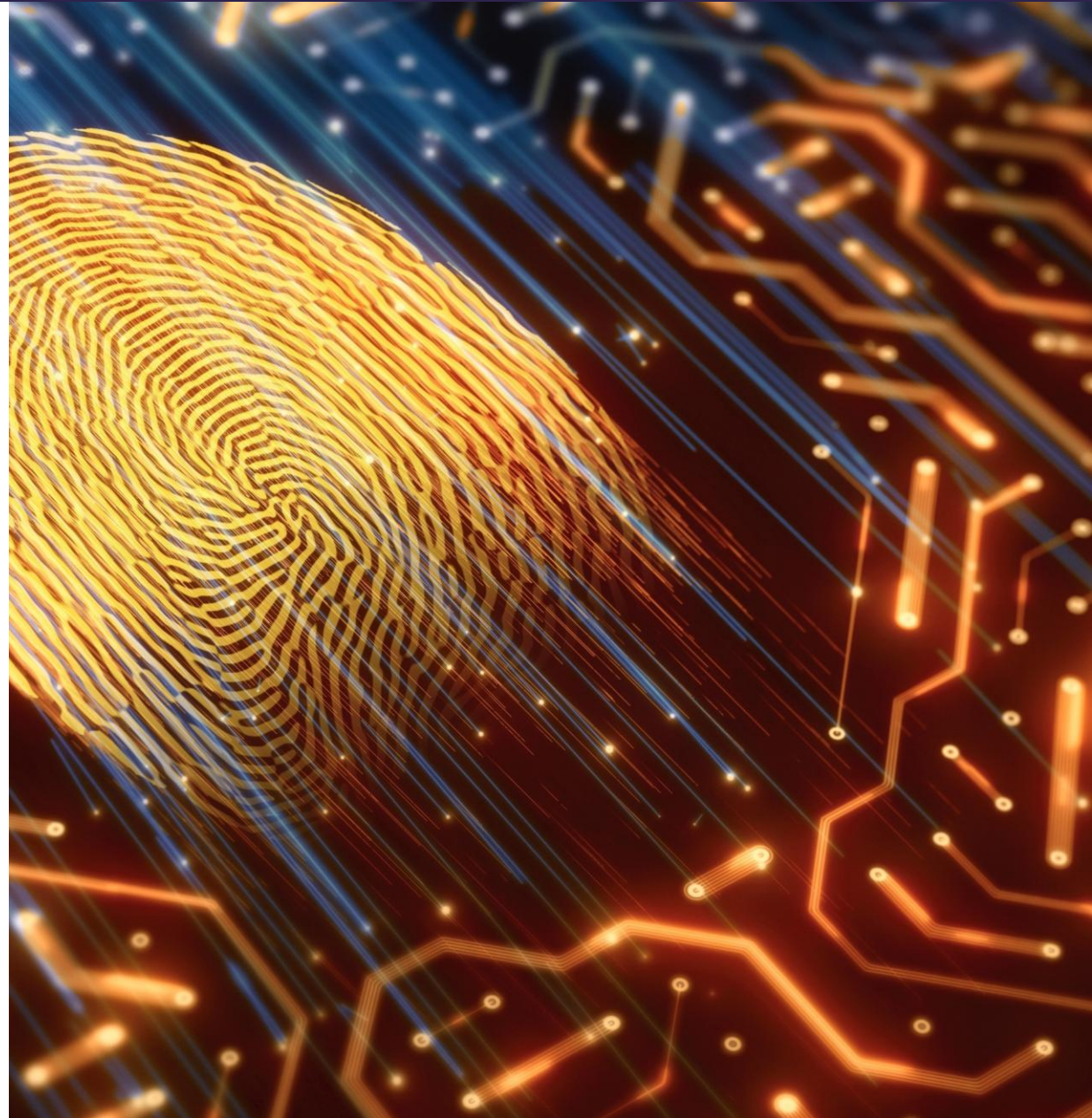
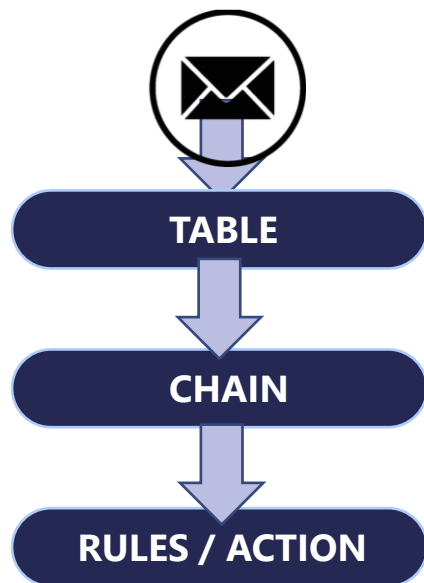
Utilizada para filtrar, controlar y registrar el tráfico de red en sistemas operativos basados en Linux.

Opera sobre el **subsistema de filtrado de paquetes del kernel de Linux**, llamado **Netfilter**, y actúa como un **muro de control (firewall de nivel de red y transporte)** que decide qué hacer con cada paquete.



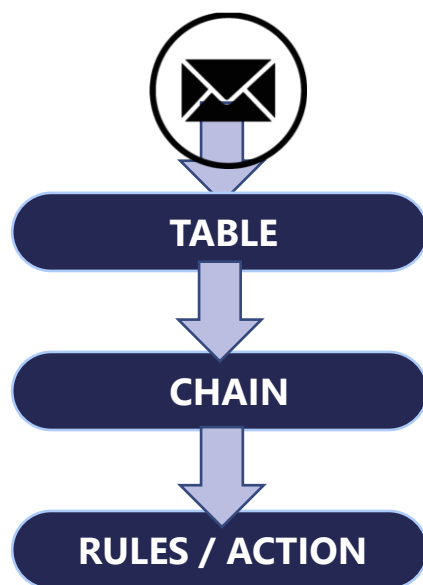
ARQUITECTURA GENERAL IPTABLES

Cuando un paquete llega o sale del sistema, el kernel lo procesa a través de **tablas y cadenas** donde se aplican reglas.



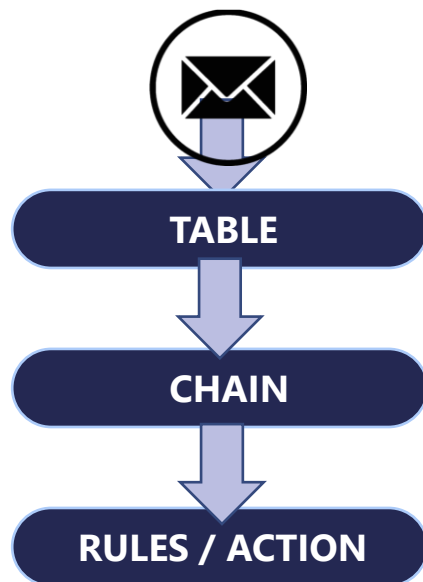
ARQUITECTURA GENERAL IPTABLES

Cada tabla tiene un propósito específico:



CADENAS IPTABLES

Cada tabla tiene un propósito específico:

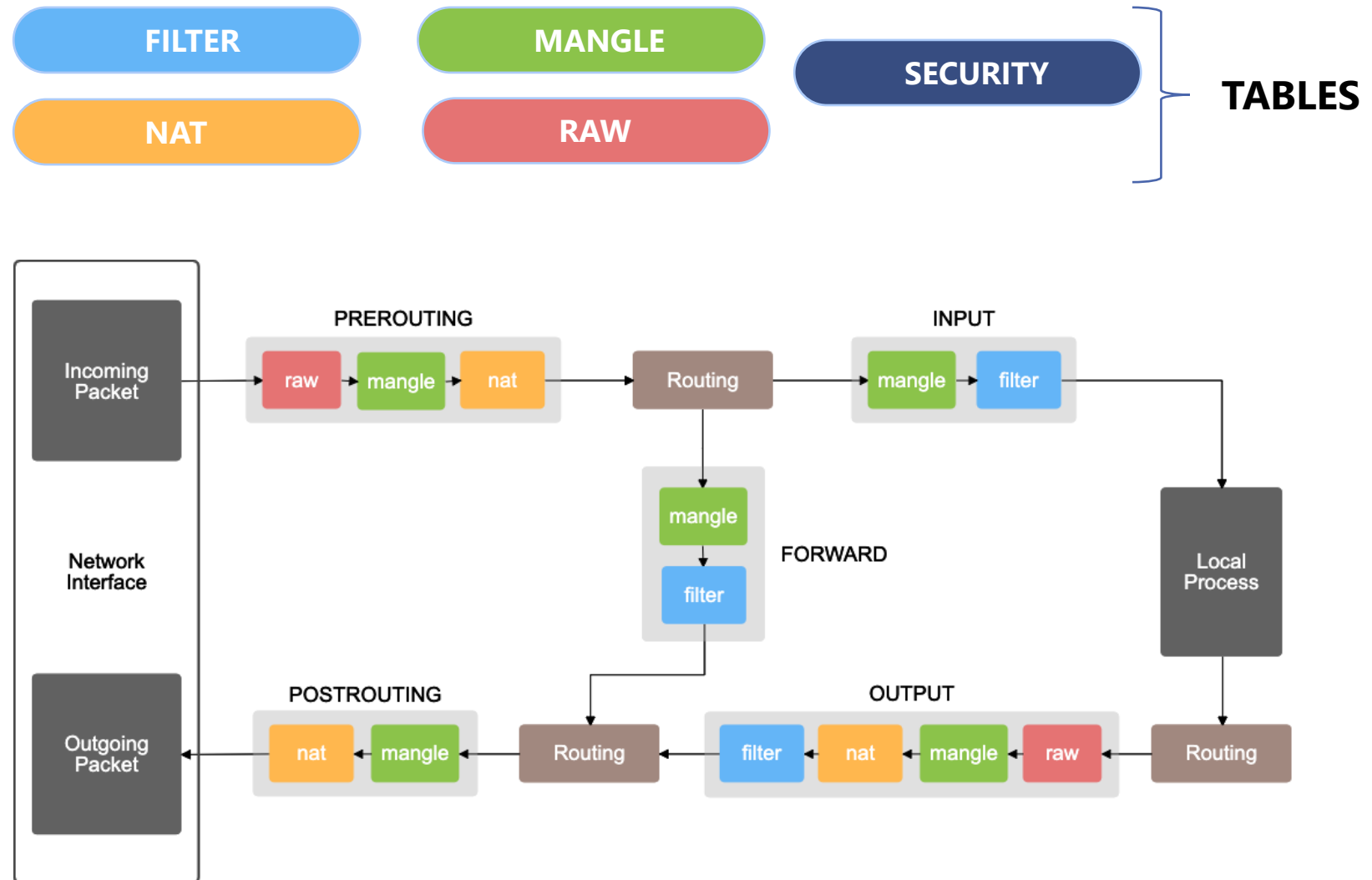
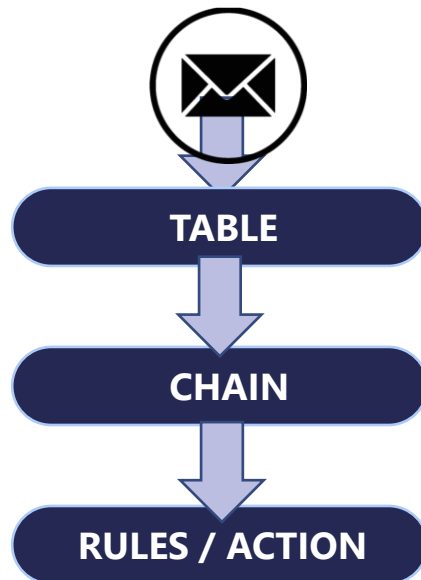


- **INPUT**
Paquetes destinados al propio host.
- **OUTPUT**
Paquetes generados por el host.
- **FORWARD**
Paquetes que atraviesan el host (rutado).
- **PREROUTING**
Modificaciones antes de rutear el paquete (NAT).
- **POSTROUTING**
Modificaciones después del ruteo (NAT).



CADENAS IPTABLES

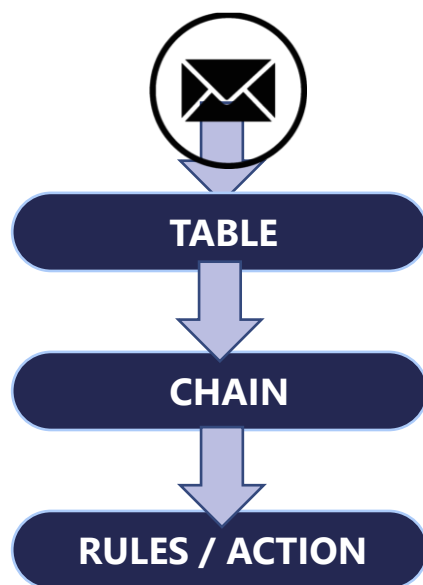
Cada tabla tiene un propósito específico:



REGLAS Y POLÍTICAS

IPTABLES

Cada **regla** define una condición y una **acción (target)** a ejecutar si se cumple.



ACCEPT

Permitir el paquete.

DROP

Desechar el paquete sin respuesta.

REJECT

Bloquear y enviar un mensaje ICMP de rechazo.

LOG

Registrar en /var/log/messages o syslog.

DNAT

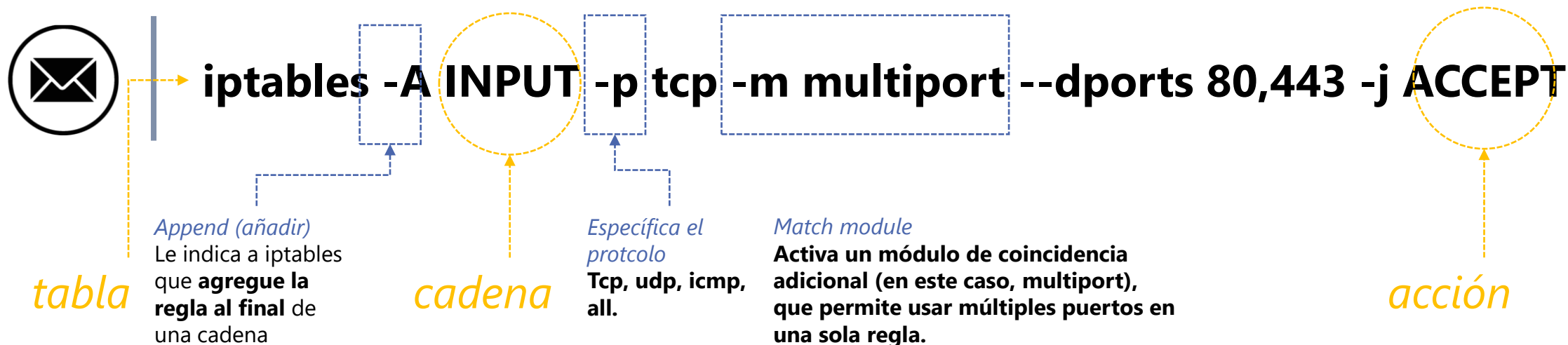
Redirigir destino (usado en NAT).

SNAT / MASQUERADE

Modificar IP de origen (salida a Internet).

#PERMITIR HTTP/HTTPS

IPTABLES



Opción	Nombre	Descripción
-A	Append	Añade una regla al final de la cadena.
-I	Insert	Inserta una regla al principio (puedes especificar la posición).
-D	Delete	Elimina una regla específica.
-R	Replace	Reemplaza una regla existente.
-L	List	Lista las reglas actuales.
-F	Flush	Elimina todas las reglas (resetea la cadena).
-P	Policy	Define la política por defecto (ACCEPT o DROP).

Opción	Nombre	Ejemplo
--sports	Puerto de origen	--sports 1024:65535
--dports	Puertos de destino	--dports 22,80,443
--ports	Ambos (origen o destino)	--ports 53,67,68

Sin -m multiport, solo podrías especificar un puerto por regla.

VARIABLES Y OPCIONES COMUNES

IPTABLES

Parámetro	Significado	Ejemplo
-s o --source	IP o red de origen	<i>-s 192.168.1.0/24</i>
-d o --destination	IP o red de destino	<i>-d 10.0.0.10</i>
-i o --in-interface	Interfaz de entrada	<i>-i eth0</i>
-o o --out-interface	Interfaz de salida	<i>-o wlan0</i>
--sport	Puerto de origen	<i>--sport 53</i>
--dport	Puerto de destino	<i>--dport 22</i>
-m state o -m conntrack	Estado de conexión	<i>--state ESTABLISHED,RELATED</i>
--limit	Límite de coincidencia	<i>--limit 5/minute</i>
--log-prefix	Prefijo para logs	<i>--log-prefix "Firewall: "</i>

Puedes listar todas las reglas activas con: **iptables -L -v -n --line-numbers**

#REGLA ROBUSTA

IPTABLES



```
iptables -A INPUT -i eth0 -p tcp -m multiport --dports 22,80,443 \  
-m state --state NEW,ESTABLISHED -j ACCEPT
```

Permite tráfico TCP entrante por la interfaz eth0 a los puertos 22, 80 y 443, siempre que sea parte de una conexión nueva o establecida.

VER Y ADMINISTRAR REGLAS DE IPTABLES

Lista reglas activas con

>_ iptables -L -v -n

Muestra las reglas en formato de

>_ iptables -S

Elimina todas las reglas.

>_ iptables -F

Reinicia contadores.

>_ iptables -Z

Exporta reglas actuales.

>_ iptables -save > archivo

Restaura reglas desde archivo.

**>_ iptables -restore <
archivo**

BUENAS PRÁCTICAS EN UN FIREWALL

01

Aplicar la **política por defecto en DROP**, y solo abrir lo necesario.

02

Guardar configuraciones persistentes (**iptables-save**).

03

Usar comentarios (**-m comment --comment "Descripción"**) para reglas complejas.

04

Implementar **registro de eventos** (LOG) antes de un DROP importante.

05

Probar reglas en entorno de pruebas antes de producción.

06

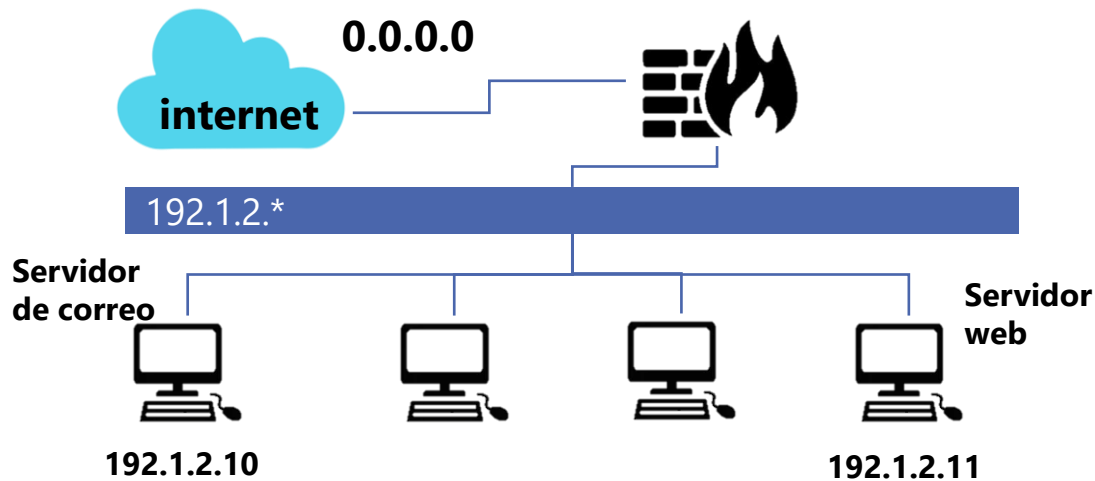
Integrar con **fail2ban**, **ufw**, o **firewalld** para gestión más sencilla.



Uncomplicated
Firewall
(ufw)

ACTIVIDAD 04 - Mecanismos de defensa en red.

Teniendo en cuenta la topología de red mostrada completa la tabla con las reglas de iptables que deberían aplicarse en el Firewall para llevar a cabo las acciones solicitadas. Las reglas, siempre que sea posible, deben determinar protocolo, dirección IP origen y destino, puerto/s origen y destino y el estado de la conexión.



1. Establecer una política restrictiva.
2. Permitir el tráfico de conexiones ya establecidas.
3. Aceptar tráfico DNS (TCP) saliente de la red local.
4. Aceptar correo entrante proveniente de Internet en el servidor de correo.
5. Permitir correo saliente a Internet desde el servidor de correo.
6. Aceptar conexiones HTTP desde Internet a nuestro servidor web.
7. Permitir tráfico HTTP desde la red local a Internet.

ACTIVIDAD 05 - Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

Objetivo general:

Analizar y comparar de manera estructurada las principales metodologías y marcos de referencia utilizados en pruebas de penetración y evaluación de seguridad informática, con el fin de que el estudiante comprenda sus enfoques, objetivos, contextos de aplicación y alcances técnicos, fortaleciendo su criterio para seleccionar y aplicar la metodología más adecuada según distintos escenarios de seguridad.

Objetivos específicos:

- **Identificar y describir** las características fundamentales de las principales metodologías de pentesting y seguridad informática, incluyendo su propósito, fases de implementación y orientación estratégica.
- **Relacionar** cada metodología con los escenarios de aplicación más adecuados, considerando el tipo de sistema, el enfoque de seguridad y el objetivo de la evaluación.
- **Comparar** las metodologías analizadas a partir de criterios como autores, documentación oficial, certificaciones y vigencia, desarrollando una visión crítica sobre su uso en contextos profesionales.

Duración aproximada:

03 horas y 25 minutos.

Instrucciones

Elabora una tabla de comparación la cual contenga las diferentes metodologías de pruebas de penetración y evaluación de la seguridad informática:

1. **MTRE ATT&CK**
2. **OWASP WSTG**
3. **NIST SP 800-115**
4. **OSSTMM**
5. **PTES**
6. **ISSAF**

Completa cada columna de la tabla de manera clara, precisa y sintetizada, considerando los siguientes aspectos:

- A. Descripción breve de la metodología.**
- B. Fases de implementación.**
- C. Objetivo principal (ejemplo: detección de técnicas de ataque, pruebas técnicas, evaluación de controles, etc).**
- D. Escenarios en los que se utiliza.**
- E. Orientación (ataque, defensa o evaluación).**
- F. Autores u organismos responsables.**
- G. URL del material oficial.**
- H. Existencia de certificaciones asociadas.**
- I. Versiones o actualizaciones vigentes.**

Investiga en fuentes oficiales y confiables la información correspondiente a cada metodología

ACTIVIDAD 05 - Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

Rúbrica de evaluación:

Criterio	Ponderación total	Excelente	Bueno	Regular	Insuficiente
01. Comprensión y descripción de las metodologías	20 pts.	18–20 pts. — Describe con claridad y precisión cada metodología; demuestra comprensión profunda de su propósito y enfoque.	14–17 pts. — Descripción correcta, aunque con menor profundidad o algunos conceptos poco desarrollados.	10–13 pts. — Descripción general, superficial o parcialmente correcta.	0–9 pts. — Descripción incorrecta, confusa o ausente; no demuestra comprensión.
02. Identificación de fases y objetivos principales	15 pts.	14–15 pts. — Identifica correctamente las fases y el objetivo principal de todas las metodologías.	11–13 pts. — Identificación correcta en la mayoría, con omisiones menores.	8–10 pts. — Superficial o repetitiva, sin aportes relevantes.	0–7 pts. — Fases u objetivos incorrectos o no identificados.
03. Relación con escenarios de aplicación	15 pts.	14–15 pts. — Relaciona adecuadamente cada metodología con escenarios concretos (web, infraestructura, organizacional, etc.).	11–13 pts. — Relación correcta, pero con ejemplos limitados o poco justificados.	8–10 pts. — Relación general o ambigua.	0–7 pts. — No logra relacionar las metodologías con escenarios reales.
04. Análisis de orientación y enfoque metodológico	20 pts.	18–20 pts. — Distingue claramente la orientación (ataque, defensa, evaluación) y la explica de forma técnica.	14–17 pts. — Identificación correcta, con explicación básica.	10–13 pts. — Identificación parcial o poco fundamentada.	0–9 pts. — Orientación incorrecta o no identificada.
05. Investigación de fuentes, autores y vigencia	15 pts.	14–15 pts. — Incluye autores, URLs oficiales, certificaciones y versiones vigentes correctamente.	11–13 pts. — Información correcta con algunos elementos incompletos.	8–10 pts. — Información superficial o desactualizada.	0–7 pts. — Fuentes ausentes, incorrectas o no confiables.
06. Organización, claridad y presentación de la tabla	15 pts.	14–15 pts. — Tabla completa, ordenada, clara y con redacción técnica adecuada.	11–13 pts. — Tabla clara, con errores menores de forma o redacción.	8–10 pts. — Presentación descuidada o poco clara.	0–7 pts. — Tabla incompleta, desordenada o difícil de comprender.
	100 pts.				

PD02 -

Objetivo general:

Desarrollar y documentar de manera estructurada las actividades prácticas de la asignatura de Seguridad Informática, mediante su integración en el portafolio digital previamente implementado (PD01), transformando los contenidos técnicos en artículos web enriquecidos que evidencien análisis, interpretación, implementación y comunicación profesional de conocimientos en ciberseguridad.

Objetivos específicos:

- Integrar una sección específica de **Actividades** dentro del portafolio digital, manteniendo coherencia estructural, navegación clara y consistencia visual con el sitio base evaluado en el PD01.
- Documentar actividades prácticas de seguridad informática en formato de **contenido web tipo blog**, incorporando análisis técnico, recursos multimedia, esquemas, topologías, referencias normativas y reflexión crítica.
- Facilitar la trazabilidad académica de las evidencias mediante la inclusión de un **mecanismo de exportación a PDF**, conservando la versión formal previamente revisada de cada actividad.

Duración aproximada:

05 horas y 25 minutos.

Instrucciones

El estudiante deberá **mantener el sitio web desarrollado en el PD01**, respetando su diseño, identidad académica y navegación general. Se deberá **crear una nueva pestaña o sección** en el menú principal denominada obligatoriamente: **"Actividades"**.

Dentro de la pestaña **Actividades**, el sitio deberá mostrar un **listado**, con las siguientes actividades del curso:

ACTIVIDAD 01 - Análisis en grupo de un ciberataque real y su impacto empresarial

ACTIVIDAD 02 - Análisis de servicios de seguridad (X.800 y RFC 4949)

ACTIVIDAD 03 - Interpretación y traducción de políticas de filtrado en iptables

ACTIVIDAD 04 - Mecanismos de defensa en red

ACTIVIDAD 05 - Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

ACTIVIDAD 06 - Implementación de IPSec VPN

Este listado deberá funcionar como un **índice tipo blog**, donde cada elemento sea un enlace a su contenido individual.

Al seleccionar una actividad, el sitio deberá mostrar una **página individual**, diseñada como un **artículo técnico digital**, no como un **archivo PDF incrustado o descargado directamente**.

Cada actividad deberá incluir, como mínimo:

1. **Introducción contextual** al tema.
2. **Desarrollo técnico de la actividad**.
3. **Material multimedia**, por ejemplo: Diagramas o topologías de red, Capturas de comandos, configuraciones o herramientas, Esquemas explicativos, Videos demostrativos propios o referenciados.
4. **Opinión o reflexión técnica del estudiante**, vinculando el tema con escenarios reales de seguridad informática.
5. **Referencias técnicas**.
6. Cada actividad deberá contar con un **botón visible de "Exportar a PDF"**, el cual permitirá descargar la versión formal del documento correspondiente a esa actividad.

Este PDF **no sustituye al contenido web**, sino que funciona como respaldo académico del artículo publicado.

PD02 -

No.	Elemento	Descripción	Puntaje
01	Contenido técnico y profundidad	El artículo desarrolla correctamente el tema, demuestra comprensión técnica, precisión conceptual y nivel acorde a la asignatura de Seguridad Informática.	01
02	Uso de material multimedia y recursos visuales	Integra adecuadamente diagramas, topologías, capturas, esquemas o videos que enriquecen y apoyan la comprensión del contenido.	01
03	Publicación web y exportación a PDF	La actividad se presenta como artículo web (no PDF incrustado), con botón funcional de exportación a PDF y correcta visualización en el sitio.	01
04	Diseño visual e innovación	El diseño del sitio demuestra creatividad, originalidad e innovación, sin afectar la legibilidad ni la funcionalidad.	01
05	Actividad 01	El contenido presenta redacción clara, ordenada y adecuada al contexto académico-técnico, facilitando su lectura y comprensión.	01
06	Actividad 02		01
07	Actividad 03		01
08	Actividad 04		01
09	Actividad 05		01
10	Actividad 06		01
		TOTAL	

PROTOCOLO ARP (ADDRESS RESOLUTION PROTOCOL)

ARP resuelve direcciones IPv4 a direcciones MAC en redes Ethernet dentro de una subred.

En pocas palabras:
"Si conozco tu IP, pero no tu MAC, uso ARP para preguntarte quién eres a nivel físico."

```

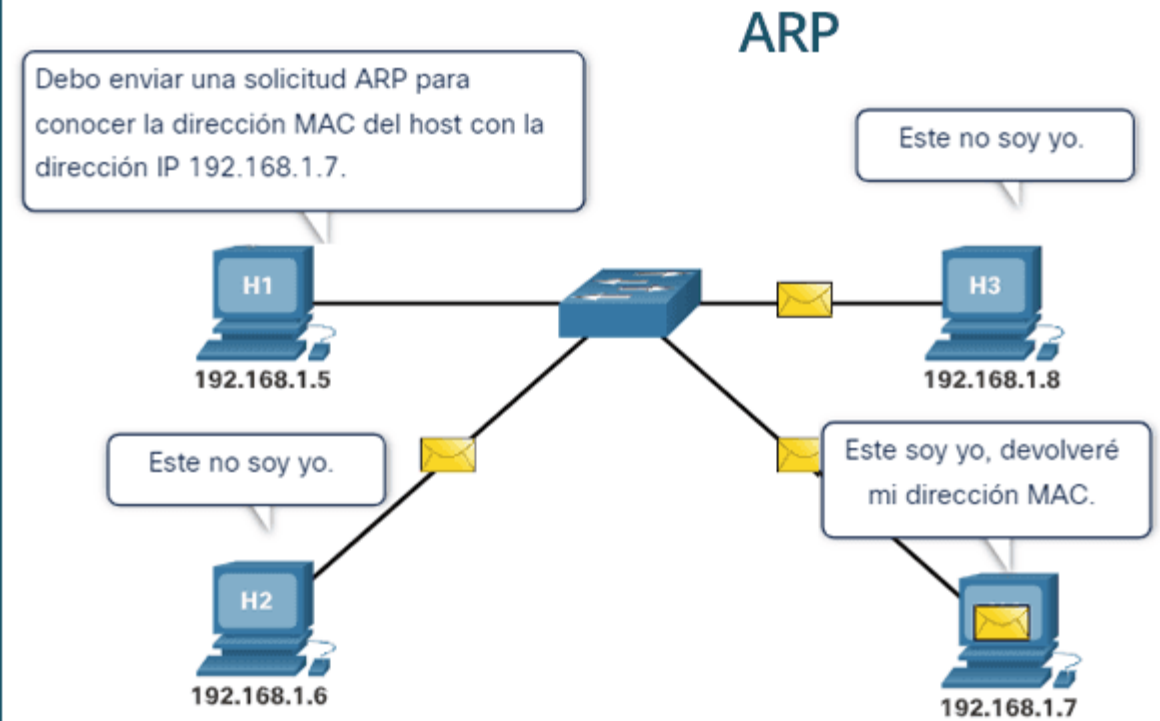
Simbolo del sistema
Microsoft Windows [Versión 10.0.26100.7171]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\usuario1>arp -a

Interfaz: 192.168.1.151 --- 0x5
Dirección de Internet    Dirección física    Tipo
192.168.1.10             cc-96-e5-20-85-5a   dinámico
192.168.1.67             cc-96-e5-20-80-5a   dinámico
192.168.1.83             cc-96-e5-26-05-d4   dinámico
192.168.1.122            6c-24-08-40-15-3b   dinámico
192.168.1.153            cc-96-e5-26-03-07   dinámico
192.168.1.157            90-09-d0-79-6e-41   dinámico
192.168.1.178            18-ec-e7-64-be-ed   dinámico
192.168.1.185            08-8f-c3-c3-82-21   dinámico
192.168.1.240            84-69-93-81-5d-c3   dinámico
192.168.1.254            78-3e-a1-82-b1-50   dinámico
192.168.1.255            ff-ff-ff-ff-ff-ff   estático
224.0.0.22              01-00-5e-00-00-16   estático
224.0.0.251             01-00-5e-00-00-fb   estático
224.0.0.252             01-00-5e-00-00-fc   estático
239.255.255.250         01-00-5e-7f-ff-fa   estático
255.255.255.255         ff-ff-ff-ff-ff-ff   estático

Interfaz: 192.168.56.1 --- 0x10
Dirección de Internet    Dirección física    Tipo
192.168.56.255          ff-ff-ff-ff-ff-ff   estático
224.0.0.22              01-00-5e-00-00-16   estático
224.0.0.251             01-00-5e-00-00-fb   estático
224.0.0.252             01-00-5e-00-00-fc   estático
239.255.255.250         01-00-5e-7f-ff-fa   estático
255.255.255.255         ff-ff-ff-ff-ff-ff   estático

C:\Users\usuario1>
  
```



PROTOCOLO DE CONEXIÓN SEGURA

Debido a las amenazas a las que se expone un mensaje por la red, los principales objetivos de la criptografía son preservar la confidencialidad de la información transmitida y garantizar tanto la integridad de la información (no ha sido modificada) como la autenticidad de los emisores/receptores de la misma.

IPSec

SSL/TLS

Redes virtuales
privadas

PROTOCOLO IPSec

IPsec (Internet Protocol Security) es un conjunto de protocolos y mecanismos criptográficos diseñado para proteger las comunicaciones IP.

Es la base de muchas VPN empresariales.

IPsec actúa directamente en la capa 3 (Red) del modelo OSI.

Es el "cerebro" del sistema.
Negocia los parámetros criptográficos.
Autentica a las partes.
Intercambia claves de sesión.
Opera en dos versiones: **IKEv1** e **IKEv2** (más seguro y usado actualmente).

IPsec tiene tres bloques clave:

01

Protocolos de seguridad.

AH (Authentication Header)

- Garantiza integridad y autenticación.
- No cifra la información.
- Protege los encabezados del paquete IP.

ESP (Encapsulating Security Payload)

- Cifra los datos → Confidencialidad.
- En la práctica moderna, casi todas las VPN utilizan ESP.

02

Modos de operación.

Modo transporte

- Solo cifra/PROTEGE la **carga útil (payload)** del paquete IP.
- Usado entre **servidores o hosts finales**.
- Cabecera IP original se mantiene visible.

Ejemplo: comunicación segura entre dos servidores.

Modo túnel

- Cifra **todo el paquete IP original** y lo encapsula dentro de uno nuevo.
- Recomendado para **VPN entre redes o enrutadores**.
- Oculta totalmente la información de origen/destino real.

Ejemplo: VPN entre dos sucursales.

03

IKE (Internet Key Exchange)

PROTOCOLO SSL/TLS

TLS (Transport Layer Security), su antecesor SSL (Secure Sockets Layer), es un protocolo criptográfico que protege la comunicación entre aplicaciones en Internet, ofreciendo: confidencialidad, integridad, autenticación del servidor.

¿En qué capa trabaja TLS?

Opera en la **capa 4.5 / 7** (entre Transporte y Aplicación), lo que significa que:

- ✓ Está por encima de TCP.
- ✓ Protege protocolos específicos como HTTP, SMTP, FTP, SSH sobre TLS, etc.
- ✓ No cifra todo el tráfico IP como IPsec, sino únicamente conexiones de aplicaciones.



PROTOCOLO SSL/TLS (Componentes principales)

TLS se compone de
dos grandes fases:

01 Handshake (intercambio inicial)

Es el proceso donde el cliente y el servidor:

- Se autentican (el servidor usando un **certificado digital**)
- Negocian la **versión de TLS**
- Seleccionan los **algoritmos criptográficos**
- Realizan un **intercambio de claves** seguro
- Establecen la **clave de sesión**

A partir de TLS 1.3, el handshake se volvió **más rápido y más seguro**.



PROTOCOLO SSL/TLS (Componentes principales)

TLS se compone de
dos grandes fases:

02 Record Protocol (transporte cifrado)

Una vez autenticado y negociado:

- Todos los datos se **cifran** con una clave simétrica de sesión.
- Cada mensaje se verifica con un **MAC** (integridad).
- Garantiza que nadie pueda leer o modificar los datos.



PROTOCOLO

SSL/TLS (Servicios de seguridad)

TLS cumple con los servicios definidos en **X.800**:

Confidencialidad

Cifrado simétrico (AES-GCM, ChaCha20, etc.).

Integridad

HMAC, AEAD

Autenticación

Certificados digitales (X.509) emitidos por una **Autoridad Certificadora (CA)**.

Control de acceso

Si el servidor autentica al cliente.

Protección contra ataques de

replay gracias al uso de nonces y claves efímeras.

PROTOCOLO SSL/TLS (Servicios de seguridad)

A diferencia de
IPsec:

- Protege *solo las aplicaciones* que lo implementan (HTTPS, IMAPS, etc.).
- No cifra metadatos como IP de origen/destino.
- No funciona automáticamente para todo el tráfico.



PROTOCOLO REDES VPN

Una **VPN (Virtual Private Network)** es una tecnología que permite crear un **túnel cifrado** a través de una red pública (como Internet) para conectar de forma **segura, privada y confiable** dos puntos:

- Un **usuario remoto** con una red corporativa
- Dos **oficinas o sucursales**
- Dos **servidores o dispositivos**
- Dispositivos móviles con un servidor central

Los principales tipos de VPN son:

VPN de Acceso Remoto (Remote Access VPN)

- Diseñadas para que usuarios externos (teletrabajo, empleados en campo) se conecten a la red corporativa.
- Cisco AnyConnect
- OpenVPN
- WireGuard
- L2TP/IPsec

VPN Sitio a Sitio (Site-to-Site VPN)

- Conecta dos redes completas a través de Internet.
- Empresas con varias sucursales
- Dependencias gubernamentales
- Universidades
- Generalmente utiliza IPsec en modo túnel.

VPN de Capa 2 y Capa 3

- Capa 2 (L2VPN), emulan un enlace ethernet, permite el tráfico de VLANs, STP, ARP, etc.
- **L2TP OpenVPN TAP MPLS/VPLS**
- Capa 3 (L3VPN), transporta solo tráfico IP.
- Ejemplo: IPsec, WireGuard, OpenVPN TUN

PROTOCOLOS MÁS USADOS EN VPN

IPSec

- Empresa, gobierno, banca.
- Excelente para *VPN sitio a sitio*
- Cifrado fuerte
- Operación en capa 3

L2TP/IPSec

- Combina tunneling (L2TP) con cifrado (IPsec).
- Antiguo pero aún usado.

SSL/TLS VPN

Opera en capa 7:

- Muy usada para acceso remoto.
- Fácil de implementar a través de HTTPS.
- Ejemplos: OpenVPN, AnyConnect.

PPTP

Obsoleto.

- Débil y vulnerable.
- No se recomienda.

WireGuard

Protocolo moderno y muy rápido.

Menos código → menos vulnerabilidades.

Basado en criptografía moderna (ChaCha20).

PROTOCOLO

¿CÓMO FUNCIONA UNA VPN

PASO A PASO?

01 El cliente inicia una conexión al servidor VPN.

02 **Autenticación**
(certificados, llaves PSK, usuario/contraseña).

03 Se negocian algoritmos, versión y claves (IPsec, TLS, WireGuard).

04 Se establece un **túnel cifrado** (encapsulación).

05 Todo el tráfico pasa por el túnel como si estuviera en la red interna

06 El servidor enruta solicitudes hacia la red corporativa.

Tunneling

Una VPN hace tunneling, que consiste

1. **Tomar el paquete original ^{en} IP.**
2. **Cifrarlo.**
3. **Encapsularlo dentro de un paquete nuevo.**
4. **Enviarlo por internet.**
5. **Desencapsularlo en el extremo receptor.**

Internet solo ve un paquete cifrado, no su contenido real.

ALGORITMO DE CIFRADO

CHACHA20

Es un **algoritmo de cifrado simétrico de flujo** (stream cipher) diseñado por Daniel J. Bernstein.

Es una versión mejorada del algoritmo **Salsa20**, con:

- **Mayor seguridad.**
- **Mejor desempeño.**
- **Mejor resistencia a ataques por canal lateral.**
- **Facilidad para implementarse en software, incluso en dispositivos sin aceleración AES.**

ChaCha20 está pensado para ser: rápido, seguro, difícil de romper, óptimo para dispositivos móviles.

Por eso reemplaza al AES en sistemas donde AES puede ser lento o vulnerable a ataques por canal lateral.



ALGORITMO DE CIFRADO

CHACHA20

ChaCha20 genera un **keystream** (flujo de claves pseudoaleatorias).

Para cifrar:

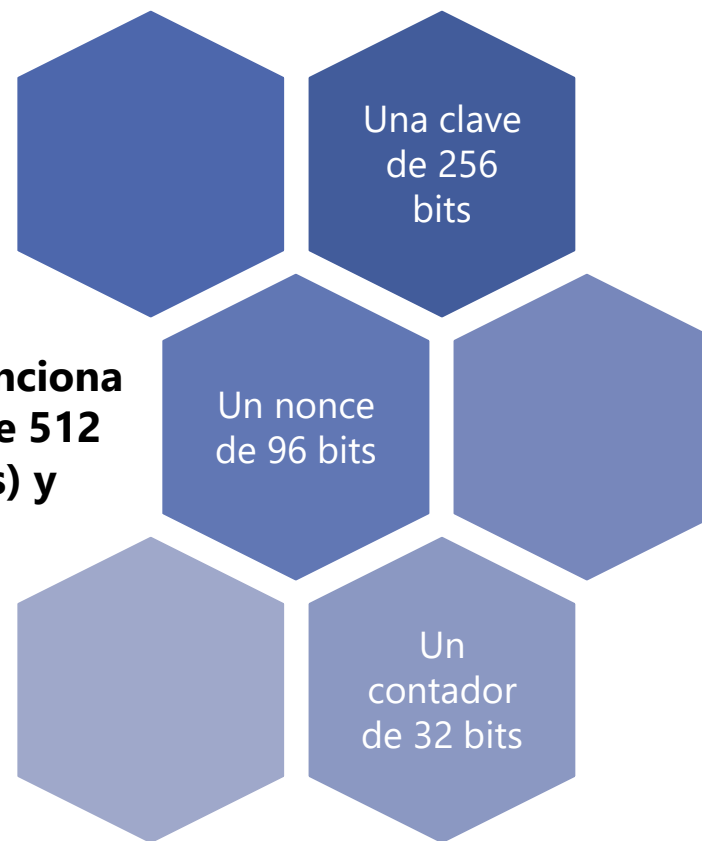
cifra = texto_plano XOR keystream

Para descifrar:

texto_plano = cifra XOR keystream

Estos elementos alimentan una matriz interna sobre la cual se aplican 20 rondas de funciones matemáticas (Quarter-Round Functions) que mezclan la clave, el nonce, el contador y constantes internas.

ChaCha20 funciona en bloques de 512 bits (64 bytes) y utiliza:



Resultado: un flujo altamente aleatorio e imposible de predecir sin la clave.

ACTIVIDAD 05 - Implementación IPsec VPN

01 Descargar e instalar cisco packet tracer

<https://www.netacad.com/resources/ab-downloads?courseLang=es-XL>

Recursos de aprendizaje



Cisco Packet Tracer

Para obtener e instalar su copia de Cisco Packet Tracer, siga estos sencillos pasos:

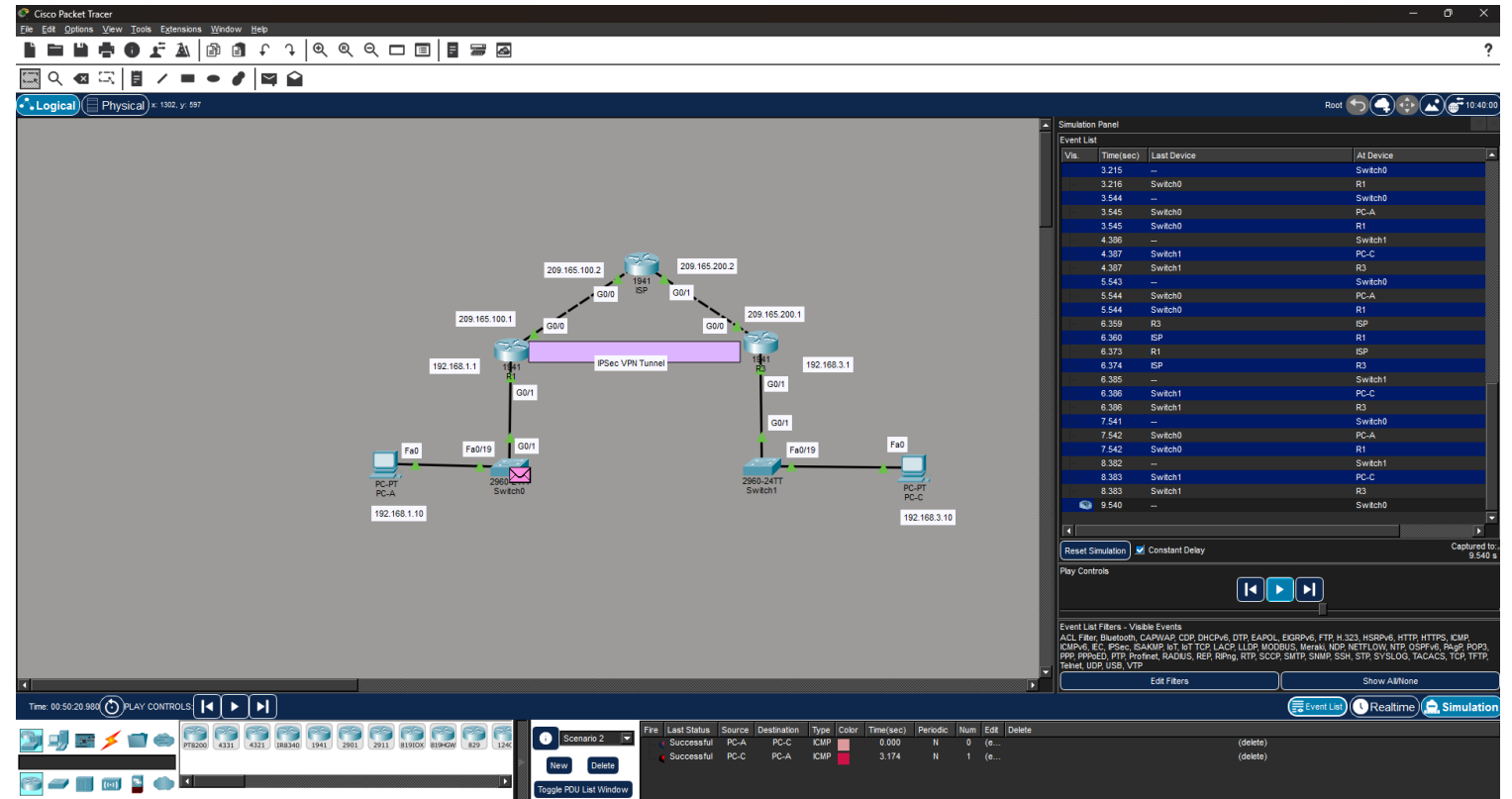
Paso 1. Descargue la versión de Packet Tracer que necesite.

Please login to download resources.

[Packet Tracer 9.0.0 Mac OS 64bit](#)
[Packet Tracer 9.0.0 Ubuntu 64bit](#)
[Packet Tracer 9.0.0 Windows 64bit](#)

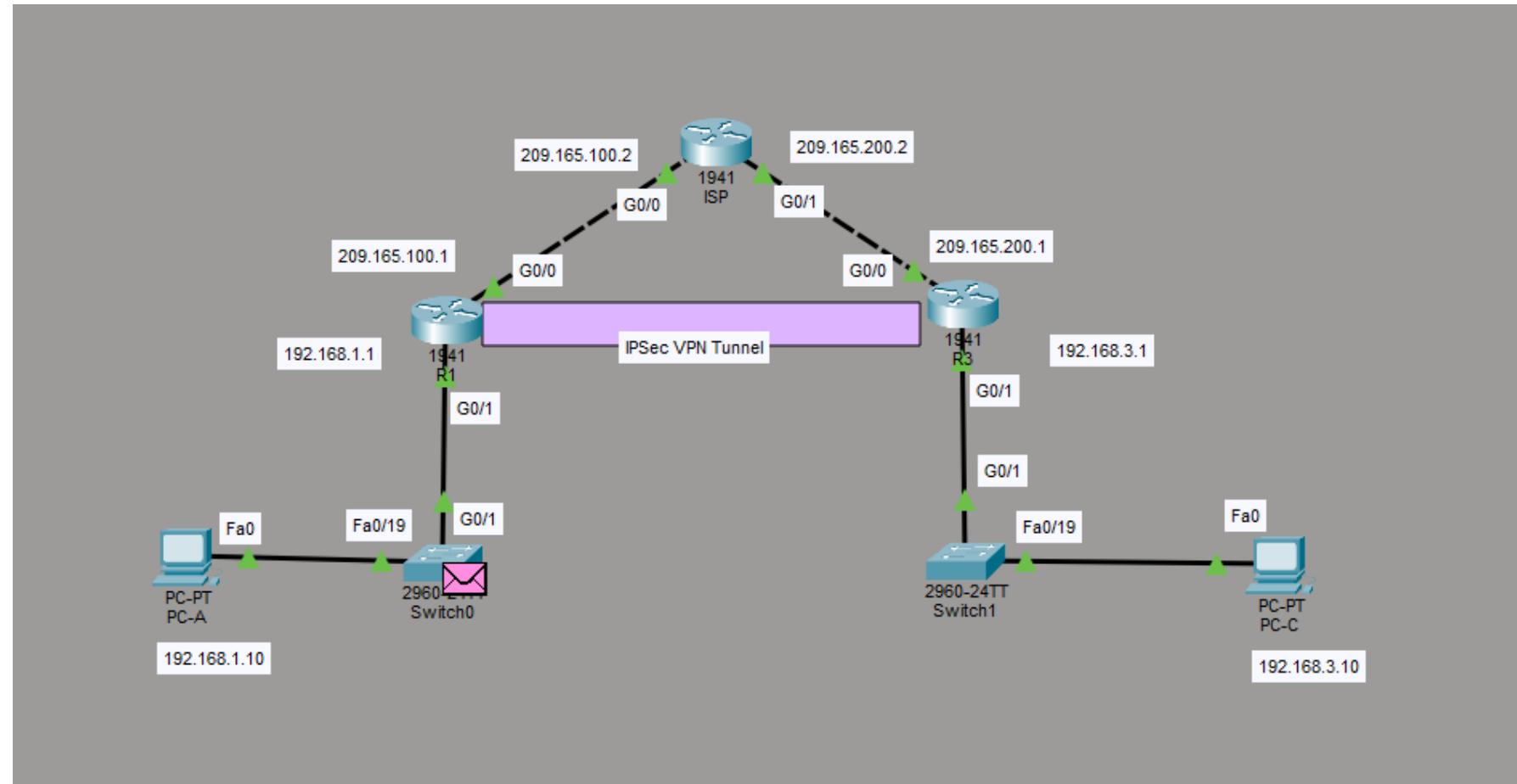
02 Registrarse e inscribirse a curso gratuito

<https://www.netacad.com/es/cisco-packet-tracer>



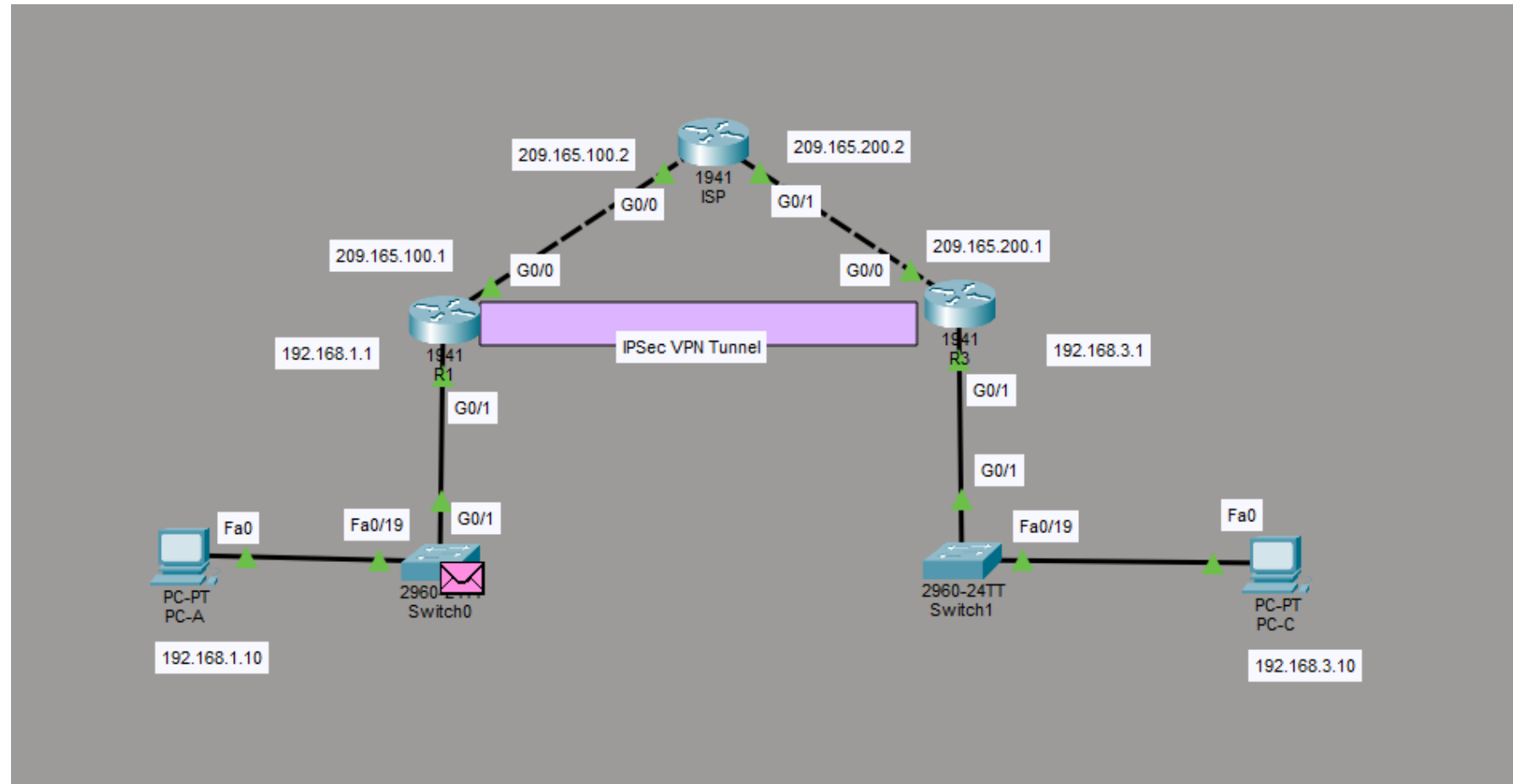
ACTIVIDAD 05 - Implementación IPsec VPN

03 Crear topología



ACTIVIDAD 05 - Implementación IPsec VPN

04 Configuración inicial



PR01 - De la teoría a la práctica: walkthrough en acción (guía y video).

Objetivo general:

Demostrar la capacidad de aplicar conocimientos teóricos de seguridad informática en un entorno práctico, mediante la realización de un walkthrough detallado y la explicación de las técnicas y metodologías utilizadas para vulnerar una máquina virtual.

Objetivos específicos:

- Configurar un entorno de virtualización aislado para realizar las pruebas de penetración de forma segura.
- Utilizar herramientas de escaneo de puertos y servicios para identificar posibles vectores de ataque.
- Enumerar los servicios y aplicaciones en ejecución para obtener información detallada sobre el sistema objetivo.
- Investigar las vulnerabilidades conocidas asociadas con los servicios y aplicaciones identificados.
- Evaluar el riesgo y la viabilidad de explotar cada vulnerabilidad.
- Seleccionar y adaptar los exploits adecuados para las vulnerabilidades encontradas.
- Escalar privilegios para obtener acceso administrativo.
- Registrar cada paso del proceso, incluyendo comandos utilizados, resultados obtenidos y capturas de pantalla.
- Explicar las técnicas y metodologías utilizadas en cada etapa del ataque.
- Grabar un video de la pantalla durante el proceso de ataque.
- Explicar cada paso del proceso en detalle, utilizando un lenguaje claro y conciso.
- Definir y explicar los términos técnicos utilizados durante el walkthrough.

Duración:

Aproximadamente 07 horas.

El proyecto busca, en primer lugar, preparar un entorno de pruebas seguro, seleccionando y configurando una máquina virtual vulnerable adecuada. A continuación, se realizará un reconocimiento exhaustivo del sistema objetivo, escaneando y enumerando los servicios en ejecución para identificar posibles vectores de ataque. El siguiente paso consiste en analizar las vulnerabilidades presentes en el sistema, investigando las vulnerabilidades conocidas y evaluando el riesgo de su explotación. Posteriormente, se procederá a explotar las vulnerabilidades identificadas para obtener acceso al sistema, seleccionando y adaptando los exploits adecuados. Una vez obtenido el acceso, se realizarán actividades de post-explotación para demostrar el control del sistema, estableciendo persistencia y escalando privilegios. A lo largo de todo el proceso, se documentará detalladamente cada paso del ataque, registrando comandos, resultados y capturas de pantalla. Además, se creará un video explicativo del walkthrough, grabando la pantalla y explicando cada paso en detalle. Un aspecto fundamental del proyecto es la explicación de los conceptos teóricos de seguridad informática relacionados con el ataque, relacionando las técnicas utilizadas con los fundamentos teóricos. Finalmente, se presentará un informe completo y un video de alta calidad que documente y demuestre el proceso de ataque.

URL de máquina virtual:

<https://www.vulnhub.com/entry/digitalworldlocal-snakeoil,738/>

PR01 - De la teoría a la práctica: walkthrough en acción (guía y video).

Criterio	Excelente	Bueno	Regular	Insuficiente
Metodología y Ejecución Técnica	Demuestra un dominio excepcional de la metodología de pentesting. Ejecuta cada fase (reconocimiento, análisis, explotación, post-explotación) con precisión y eficiencia. Utiliza herramientas y técnicas avanzadas de manera efectiva. Valor (02)	Sigue la metodología de pentesting de manera adecuada. Ejecuta las fases con cierta precisión, aunque puede haber pequeñas omisiones o errores. Utiliza herramientas y técnicas estándar de manera competente. Valor (01)	Muestra una comprensión básica de la metodología de pentesting, pero la ejecución es inconsistente o incompleta. Hay omisiones y errores significativos en la ejecución de las fases. El uso de herramientas es limitado o incorrecto. Valor (0.5)	No demuestra comprensión de la metodología de pentesting. La ejecución es confusa y llena de errores. Hay falta de uso de herramientas o un uso completamente incorrecto. Valor (0)
Explicación Teórica y Conceptos	Demuestra un conocimiento profundo de los conceptos teóricos de seguridad informática. Explica claramente los términos técnicos y relaciona las técnicas utilizadas con los fundamentos teóricos. Las explicaciones son precisas y detalladas. Valor (02)	Muestra un buen entendimiento de los conceptos teóricos. Explica los términos técnicos de manera adecuada y relaciona las técnicas con los fundamentos teóricos. Valor (01)	Muestra una comprensión básica de los conceptos teóricos, pero las explicaciones son vagas o incompletas. Hay dificultad para relacionar las técnicas con los fundamentos teóricos. Valor (0.5)	No demuestra comprensión de los conceptos teóricos. Las explicaciones son confusas o incorrectas. Hay falta de relación entre las técnicas y los fundamentos teóricos. Valor (0)
Documentación e Informe	El informe es exhaustivo, claro y bien estructurado. Incluye todos los pasos del proceso, comandos utilizados, resultados y capturas de pantalla de alta calidad. Las explicaciones son detalladas y precisas. Valor (03)	El informe es completo y bien organizado. Incluye la mayoría de los pasos, comandos y resultados. Las explicaciones son claras y comprensibles. Valor (02)	El informe es incompleto o desorganizado. Faltan pasos, comandos o resultados importantes. Las explicaciones son vagas o confusas. Valor (01)	El informe es muy incompleto, desorganizado o ausente. Faltan elementos clave y las explicaciones son incomprensibles. Valor (0)
Video Explicativo	El video es de alta calidad, claro y bien editado. La explicación de cada paso es detallada, concisa y fácil de seguir. Utiliza anotaciones y gráficos para resaltar puntos clave. La presentación es profesional y atractiva. Valor (03)	El video es claro y bien explicado. La mayoría de los pasos son fáciles de seguir. La edición es adecuada y la presentación es buena. Valor (02)	El video es confuso o difícil de seguir en algunas partes. La explicación es incompleta o vaga. La edición es deficiente y la presentación es mediocre. Valor (01)	El video es incomprensible, mal editado o ausente. La explicación es confusa o inexistente. La presentación es muy pobre. Valor (0)